

ISO/IEC 27001 Internal Audit Guide

Purpose

Folder 09 demonstrates an internal audit cycle for an ISO 27001 ISMS: planning, criteria, evidence collection, sampling, findings, reporting and follow-up.

Audit independence

Internal auditors should be objective and impartial. Where practical, auditors should not audit their own work.

Audit methods

Use interviews, document review, observation, sampling and verification of objective evidence. Do not rely only on verbal claims.

Finding discipline

A finding should identify the requirement, objective evidence and the gap or conclusion. Avoid unsupported statements.

Nonconformity vs observation

A nonconformity indicates failure to meet a requirement. An observation/opportunity for improvement identifies a potential weakness or improvement without necessarily establishing nonconformity.

Corrective action

Corrective action should address the cause of a nonconformity, not merely the symptom. Effectiveness should be checked after implementation.

Portfolio note

The audit records in this folder are simulated demonstration documents. They are not evidence of a real audit or certification.